



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-48558 SimpleHelp Authentication Bypass KEV Exposure Report

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-30
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-48558 SimpleHelp Authentication Bypass KEV Exposure Report - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-30 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2026-48558 SimpleHelp Authentication Bypass KEV Exposure Report

1. Executive Summary

CISA added CVE-2026-48558 to the Known Exploited Vulnerabilities catalog on 2026-06-29. Public research describes a SimpleHelp authentication bypass affecting OpenID Connect deployments, with risk concentrated around RMM servers that can administer downstream endpoints.

Defenders should treat this as a priority exposure-management item because the public reporting combines vulnerable internet-reachable software, credible exploitation or exploitation potential, and high-value administrative workflows. This report intentionally separates confirmed source facts from operational assumptions so asset owners can validate local exposure before emergency change windows.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-48558
Product / Component	SimpleHelp remote monitoring and management deployments using OpenID Connect
Weakness	Authentication bypass / validation gap in OIDC authentication flow
Severity	Critical priority (CISA KEV added 2026-06-29; vendor/security reporting describes administrative compromise potential)
Affected Versions	Reportedly SimpleHelp versions up to and including 5.5.15 and 6.0 prerelease builds; validate against vendor guidance
Fixed Versions / Remediation	Upgrade to vendor-fixed SimpleHelp release; disable or restrict vulnerable OIDC configuration until remediated
Disclosure / KEV Context	CISA KEV dateAdded 2026-06-29; remediation due date 2026-07-02 for covered federal systems
Exploitation Status	CISA KEV confirms known exploited status; Horizon3 reporting describes observed exploitable conditions and IOCs

3. Source Review & Confidence

Source	Contribution	Confidence
CISA Known Exploited Vulnerabilities Catalog	Confirms KEV addition date and remediation urgency	High
Horizon3.ai CVE-2026-48558 SimpleHelp Authentication Bypass IOCs	Research timeline, exploitability context, and IOC guidance	High
Help Net Security SimpleHelp RMM flaw coverage	Defender-facing summary of OIDC affected configuration	Medium
Center for Internet Security advisory	Enterprise mitigation context	Medium

Confidence is medium-high for prioritization. The KEV/vendor/security-research sources establish exposure and remediation direction; local exploitability still depends on deployed version, authentication configuration, internet exposure, and compensating controls.

4. Vulnerability Details

The reported flaw affects the authentication boundary around SimpleHelp OIDC deployments. If an attacker can bypass authentication or create privileged access, an RMM server becomes a high-leverage pivot because it can reach managed endpoints and may hold trusted remote-support capabilities.

5. Attack Scenarios

Scenario	Attacker Objective	Defender Priority
Internet-facing vulnerable instance	Establish administrative access or code execution path from the edge	Patch or isolate immediately; review access logs
Third-party managed service path	Abuse trusted remote management or PLM workflows to reach downstream systems	Confirm MSP/vendor ownership and contractual patch SLAs
Internal high-value application	Move from foothold to privileged business application	Segment, monitor authentication anomalies, and hunt for web shells or new admin accounts

6. Threat Landscape & Exploitation Status

The prioritization driver is not just CVSS-style severity; it is the combination of RMM blast radius and CISA KEV inclusion. Horizon3 and secondary defender advisories describe real-world exploitable configurations and recommend urgent remediation.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters	Evidence to Collect
Public login/API surface	Internet exposure compresses exploitation timelines	External attack-surface inventory, reverse-proxy logs
Privileged administrative console	Compromise can create durable access	Account creation logs, role changes, IdP audit records
Business-critical workflow	Outage or tampering can affect operations	Application logs, backup/restore readiness, change records

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Vulnerability management	Identify affected assets and validate fixed versions or vendor mitigations within 24 hours.
High	Network/security engineering	Remove direct internet exposure where possible; require VPN/ZTNA and strong IdP controls.
High	Detection engineering	Deploy the hunts below against web, identity, endpoint, and network telemetry.

Medium	Incident response	Preserve relevant access logs before rotation and review for suspicious account or file activity.
--------	-------------------	---

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
New administrator or service account near vulnerable app activity	IdP/application audit logs	Detect privilege establishment after exploitation
Unusual POST/API activity to vulnerable service	WAF/reverse proxy/web logs	Detect exploitation attempts and reconnaissance
Web shell or unexpected child process	EDR/process telemetry	Detect post-exploitation execution

9.2. Sigma / Detection Rule

<pre> title: Suspicious Administrative Change Near CVE-2026-48558 Exposure status: experimental description: Detects account creation or privilege changes around a vulnerable application maintenance window. logsource: product: windows service: security detection: selection: EventID: - 4720 - 4728 - 4732 - 4756 condition: selection level: high </pre>

9.3. Hunt Query

<pre> DeviceNetworkEvents where Timestamp > ago(14d) where RemoteUrl has_any ("simplehelp", "openid", "oidc") summarize Connections=count(), Devices=dcount(DeviceName) by RemoteUrl, InitiatingProcessFileName order by Connections desc </pre>

10. Threat Hunting

10.1. Hunt Hypothesis

A vulnerable exposed service was probed or exploited before patching, followed by identity changes, suspicious child processes, or outbound callback activity.

10.2. Hunt Query

<pre> DeviceProcessEvents where Timestamp > ago(14d) where InitiatingProcessCommandLine has_any ("SimpleHelp", "simplehelp", "service", "remote") or ProcessCommandLine has_any ("cmd.exe", "powershell", "curl", "wget", "certutil", "jsp", "webshell") project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName, ProcessCommandLine </pre>

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Primary risk is exploitation of reachable vulnerable services.
T1078	Valid Accounts	Successful abuse may create or use privileged accounts.
T1505.003	Server Software Component: Web Shell	Web-shell deployment is a plausible post-exploitation path for RCE-class enterprise app exploitation.

12. Validation / Lab Testing

No exploit reproduction was performed in this automated production run. Validation completed: source triangulation, affected-surface analysis, detection/hunt content generation, render QA, and PDF text extraction. Operators should validate version inventory and telemetry field names in their own environment before operational use.

13. Recommended Actions Summary

Priority	Action	Expected Outcome
Critical	Patch or apply vendor mitigation for confirmed affected instances.	Remove known exploit path.
High	Hunt for exploitation indicators and suspicious admin changes.	Identify possible pre-patch compromise.
Medium	Add the application to recurring external attack-surface monitoring.	Reduce future exposure window.

14. References

- [1] CISA Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [2] Horizon3.ai CVE-2026-48558 SimpleHelp Authentication Bypass IOCs — <https://horizon3.ai/attack-research/disclosures/cve-2026-48558-simplehelp-authentication-bypass-iocs/>
- [3] Help Net Security SimpleHelp RMM flaw coverage — <https://www.helpnetsecurity.com/2026/06/16/simplehelp-rmm-cve-2026-48558/>
- [4] Center for Internet Security advisory — https://www.cisecurity.org/advisory/a-vulnerability-in-simplehelp-could-allow-for-authentication-bypass_2026-061